

Hafta 3: Siber Güvenlik

–Saniye Topal

Görev 3: System Engineer Raporu

Bölüm A : Teori ve Mimari (Research and Logic)

1.Linux Mimarisi : Her şey bir dosyadır. (Everything is file.)

Linux işletim sistemi, tekil hiyerarşik dosya yöntemi benimsenmiştir. Bu sayede çok kullanıcı ve dağıtık bir sistem kurulup yönetilebilmektedir asıl kolaylığı burada sağlar ancak işletim sistemi tek kullanıcı tarafından da kullanılabilir. /dev/sda (Harddisk), /dev/tty (Terminal) veya /dev/null (Kara delik) gibi donanımlar bile bu dosya sisteminin yolu olabilmesiyle ; araç birliği ve komut uyumu sağlar; örneğin kök dizinleriyle cat metin ifadesini kullanarak harddisk imajını alabilir örnek kod: cat/dev/sda>disk_yedeği.img

pipe ve yönlendirme operatörleriyle veri imha etmek, ağ üzerinden disk imajı gibi donanım işlemlerini daha az komutla gerçekleştirmenizi sağlar. Soyutlama(abstraction) ve basitlik sağlar.

Tehlikeli izinler ve SUID biti:

777 tehlikesi: Chmod , change mode anlamına gelir.Bu komut erişim modunu değiştirmek için kullanılır. Chmod 777 komutu ise dosya sahibine,gruba ve herkese okuma yazma ve çalıştırma izni verir. Bu da saldırganların da dosyalara erişip zararlı PHP dosyaları gibi zararlı yazılımları yükleyebileceği ve öncesinde yüklenen dosyalardaki verilere erişebileceği anlamına gelir.

SUID(Set user ID):SUID biti normalde sadece dosyayı çalıştırma yetkisinin dosya sahibine ait olduğu dosyada kullanıcıya geçici olarak root yani sitem yöneticisi hakları verir. passwd komutu da SUID biti ayarlı bir komut olduğundan kullanıcı olarak giren kişi yetkisi olmasa da kendi şifresini değiştirebilir. Hackerlar genellikle sisteme giriş yaptıklarında düşük yetkili kullanıcı olarak girerler. Hedefi ise root olmaktır. SUID biti tanımlayabileceği dosyalarda açık ra-arayarak onları hedef alır. Örneğin dosya sahibi vim, nano, python veya find ile SUID biti tanımladıysa saldırgan bu dosyaları hedef alır.

Bash gücü ve GUI: Excel, Notepad gibi GUI araçları verileri batch (yığın) işleme şekliyle(tüm veriyi alır sonra istenene göre filtreler) yaptığından veri boyutu ram kapasitesinden fazla olduğunda sistem çöker. Linux terminalinde ise bash gücüyle - grew, apk , pipe operatörleriyle stream işleme şekliyle - veriler işlenir. Bu yöntemde veriler küçük küçük rame gelir ve istenen veriler dışındaki veriler tutulmaz.. Bash gücü ile veriler daha hızlı analiz edilir örneğin sadece 404 hatası veren IPleri tespit ederek saldırganları kısa sürede belirleyerek güvenlik duvarında müdahale edebilme şansı yakalayabiliriz.

2.Windows Eternals:Çarklar Nasıl Dönüyor

User Mode vs.Kernel Mode: Modern işlemciler ve Windows User ve Kernel mode olmak üzere uygulamaları 2 farklı şekilde yönetirler örneğin web sayfaları, kelime işlemciler , video oynatıcılar gibi uygulamalarda donanıma ve bilgisayar kaynaklarına erişimin kısıtlı mod olan user mode kullanılır. Bunun nedeni bir uygulama çöktüğünde diğer uygulamaları etkilememesini veya bir uygulamanın diğer uygulamaların verilerini değiştirmemesini sağlar bunu diğer uygulamalardan izole özel bir belleği kullanıcı moduna ayırarak yapar. Kernel mod ise çekirdek moddur. Bilgisayarın donanımına ve kaynaklarına tam erişim sağlar. Bir uygulama çöktüğünde tüm sistem çökebilir. Çekirdek modunda, sanal adres alanı ayrımı yoktur; bu moddaki tüm kodlar bellekte aynı sanal adres alanını paylaşır. Bilgisayar sisteminde ayrıcalık halkaları bulunur. Ring 0 kernel moddur en yüksek ayrıcalık ona tanınır. Ring 3 ise user moddur. RİNG 1-2 ise sitem mimarisine bağlı olarak bazı denetleyici düzeyi olabilir. chrome.exe sayfası hata verdiğinde ona ayrılan bellek silinir ve diğer uygulamaları zarar vermez çünkü user mode ile kullanılır. Ama ekran kartında bir sorun olduğunda ekran kartı kernel modda çalıştığından ondaki sorun tüm sistemin çökmesine , verilerin bozulmasına , donanımın fiziksel zarar görmesine neden olur bu yüzden mavi ekran vererek sistem kontrollü bir şekilde çöker.

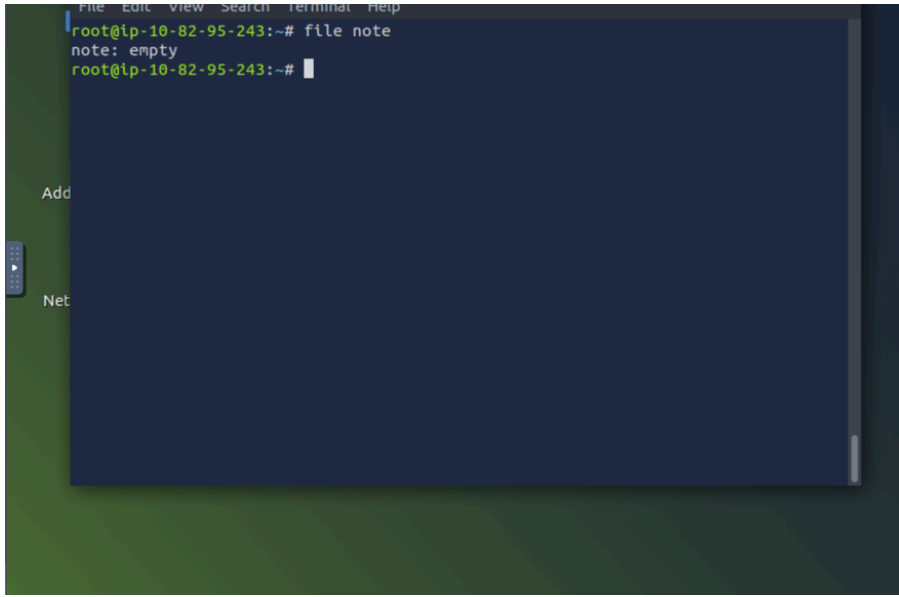
Registry (Kayıt) Defteri Anatomisi: HKLM sistemin genel ayarlarını , donanım yapılandırma bilgilerini oturum açmayan kullanıcıların sistemdeki işlemlerini kayıt ederken HKCU sadece sistemde oturum açmış kullanıcıların işlemlerini kayıt eder. Bir bilgisayara zararlı yazılımlardan trojan bulaştığında saldırgan sistemde kalıcı olabilmek için run, runonce, winlogon şeklinde sisteme kendilerini yazarlar.

NTFS izinleri ve ACL(Erişim Kontrol Listesi): ACL sisteme erişim izinlerini listeler sisteme erişimler farklı şekilde kısıtlanabilir veya izin verilebilir okuma, değiştirme, başkasına erişim izni verme gibi bu sayede iç tehditler engellenir, ransomware yazılımlarında risk azaltılır eğer sadece okuma yetkisi olan bir kullanıcının hesabı üzerinden işlem yapılırsa dosyalar değiştirilemez, kimin hangi dosyaya erişmeye çalıştığı SACL üzerinden denetlenir.

Bölüm B:Saha Eğitimi (TryHackMe Lab)

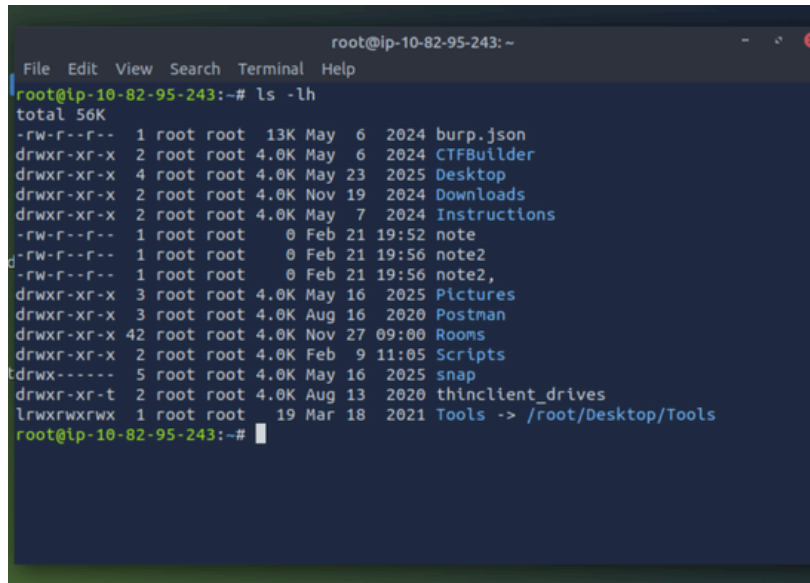
Linux Cephesi: Terminalle Tanışma

1. file note: dosya türünü belirler.



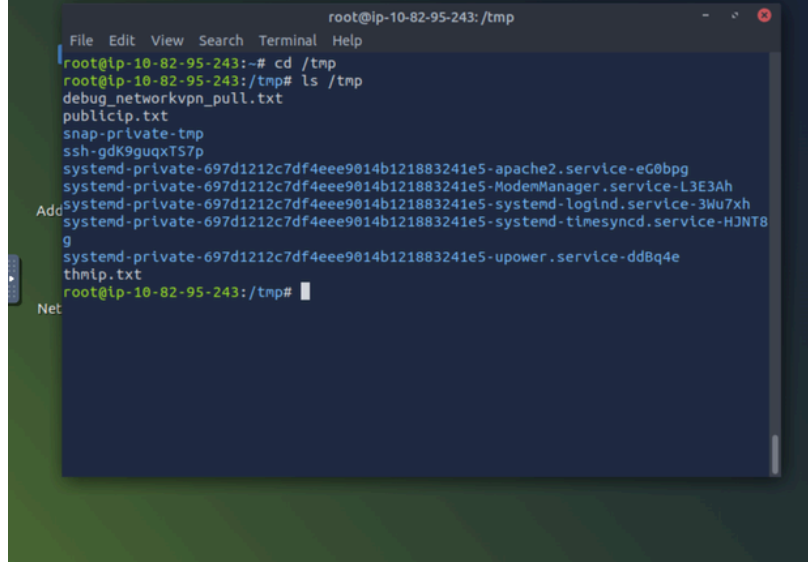
```
File Edit View Search Terminal Help
root@ip-10-82-95-243:~# file note
note: empty
root@ip-10-82-95-243:~#
```

2. ls -lh: dosya ve klasör bilgilerini detaylı bir şekilde gösterir sahibi izinleri gibi.



```
root@ip-10-82-95-243: ~
File Edit View Search Terminal Help
root@ip-10-82-95-243:~# ls -lh
total 56K
-rw-r--r-- 1 root root 13K May 6 2024 burp.json
drwxr-xr-x 2 root root 4.0K May 6 2024 CTFBuider
drwxr-xr-x 4 root root 4.0K May 23 2025 Desktop
drwxr-xr-x 2 root root 4.0K Nov 19 2024 Downloads
drwxr-xr-x 2 root root 4.0K May 7 2024 Instructions
-rw-r--r-- 1 root root 0 Feb 21 19:52 note
-rw-r--r-- 1 root root 0 Feb 21 19:56 note2
-rw-r--r-- 1 root root 0 Feb 21 19:56 note2,
drwxr-xr-x 3 root root 4.0K May 16 2025 Pictures
drwxr-xr-x 3 root root 4.0K Aug 16 2020 Postman
drwxr-xr-x 42 root root 4.0K Nov 27 09:00 Rooms
drwxr-xr-x 2 root root 4.0K Feb 9 11:05 Scripts
drwx----- 5 root root 4.0K May 16 2025 snap
drwxr-xr-t 2 root root 4.0K Aug 13 2020 thinclient_drives
lrwxrwxrwx 1 root root 19 Mar 18 2021 Tools -> /root/Desktop/Tools
root@ip-10-82-95-243:~#
```

3. /tmp: dosyaları geçici depolar genelde sisteme sızma olduğunda ilk bakılan yerlerdendir çünkü yazma yetkisi açıktır



```
root@ip-10-82-95-243: /tmp
File Edit View Search Terminal Help
root@ip-10-82-95-243:~# cd /tmp
root@ip-10-82-95-243:/tmp# ls /tmp
debug_networkvpn_pull.txt
publicip.txt
snap-private-tmp
ssh-gdK9guqxTS7p
systemd-private-697d1212c7df4eee9014b121883241e5-apache2.service-eG0bpg
systemd-private-697d1212c7df4eee9014b121883241e5-ModemManager.service-L3E3Ah
systemd-private-697d1212c7df4eee9014b121883241e5-systemd-logind.service-3Wu7xh
systemd-private-697d1212c7df4eee9014b121883241e5-systemd-timesyncd.service-HJNT8
systemd-private-697d1212c7df4eee9014b121883241e5-upower.service-ddBq4e
thmip.txt
root@ip-10-82-95-243:/tmp#
```

Bölüm D: Mühendislik Vizyonu (Reflection)

1.Yetki Yükseltme(PrivEsc) Mantığı: vim gibi bir metin düzenleyiciye SUID biti atandığında , program root yetkisine sahip olarak yüklenir. Bu durum her kullanıcının erişemeyeceği /etc/shadow sistem dosyalarına erişerek şifrelerin değiştirilmesine veya /etc/sudoers dosyasına kullanıcı kimliğine yetkiler atamasına sebep olur. Bu şekilde tüm sistemin yönetimini ele geçirebilir.

2.Zararlı Yazılım Kamufleji(Process Injection):Bir malware geliştiricis oyun.exe gibi sistem dışında değil de sistemin içindeki svchost.exe veya explorer.exe sürecinin içine enjekte olur bunun nedeni antivirüs sitemlerinin kendi içindeki güvenilir olarak işaretlediği sistemin kendisine ait olan süreçleri sürekli tarayarak sistemi yormak istememesi .Görev yöneticisine bakan bir kullanıcı, onlarca kopyası çalışan bu sistem dosyaları arasında zararlıyı fark edemeyebilir. ve bu kısımlardaki yetkinin çok yüksek olması svchost da direkt system üzerinden işlem yaparken explorer da ise yapılan tüm hareketleri izleme şansı yakalar.